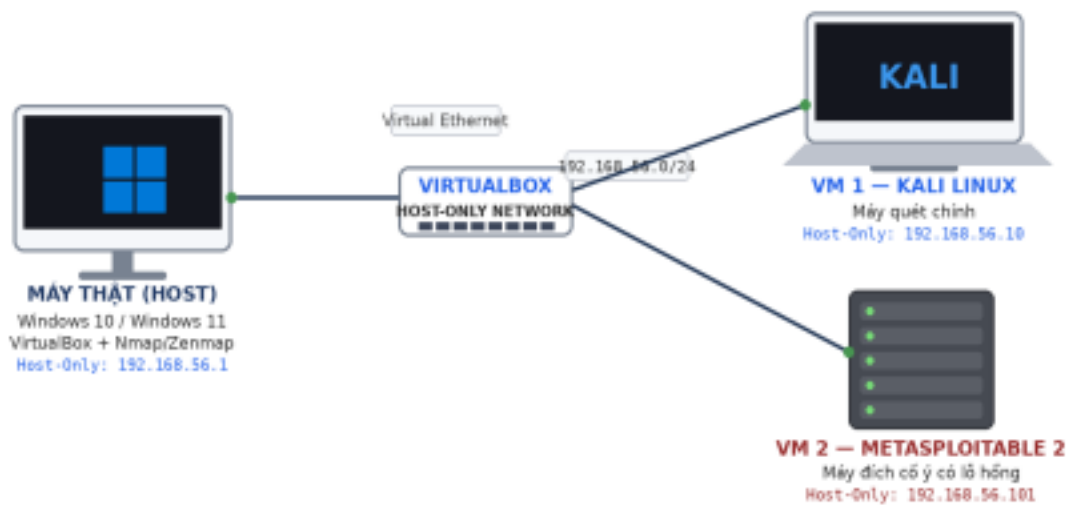


AN TOÀN HỆ THỐNG THÔNG TIN

LAB 4

KHẢO SÁT VÀ ĐÁNH GIÁ BỀ MẶT MẠNG BẰNG NMAP



CÁC ANH CHỊ NÊN GHI NHỚ!

**BÀI LAB CHỈ SỬ DỤNG ĐỂ NGHIÊN CỨU VÀ HỌC TẬP,
KHÔNG MANG TÍNH CHẤT PHÁ HOẠI HOẶC CÓ MỤC
ĐÍCH XẤU!**

Anh/chị chỉ quét các máy ảo do chính mình dựng trong mạng Host-Only. Không quét IP/tên miền bên ngoài nếu không có ủy quyền. Tất cả lệnh trong tài liệu được trình bày nhằm mục đích học tập và nghiên cứu, không dùng cho mục đích phá hoại. *Tôi hoàn toàn không chịu trách nhiệm nếu anh/chị gây ra những lỗi nghiêm trọng cho người khác!*

MỤC LỤC

1. Mục tiêu, phạm vi và quy định thực hành.....	4
1.1. Chuẩn bị môi trường.....	4
1.2. Quy tắc “tự gõ lệnh”	
2. Cài đặt Nmap trên Windows 10/11	
2.1. Các bước cài Nmap + Npcap + Zenmap trên Windows.....	
2.2. Kiểm tra địa chỉ IP Host-Only trên Windows	
6	
3. Cài đặt Nmap trên Kali Linux.....	6
3.1. Kiểm tra và cài Nmap bằng apt	
3.2. Cài Zenmap trên Kali (tùy chọn).....	
7	
4. Dựng môi trường máy ảo an toàn trên máy cá nhân.....	8
4.1. Thiết lập Host-Only trong VirtualBox.....	8
4.2. Lấy IP thật của từng máy.....	9
4.3. Kiểm tra kết nối trước khi quét.....	9
5. Tình huống giả lập: Rà soát an toàn mạng nội bộ.....	9
5.1. Nhiệm vụ 1 - Phát hiện các host đang hoạt động	9
6. Khảo sát cổng TCP và so sánh kỹ thuật quét.....	10
6.1. TCP Connect scan (-sT).....	10
6.2. SYN scan (-sS)	10
6.3. FIN / Xmas / NULL scan.....	11
6.4. ACK scan - quan sát chính sách lọc	11
7. Quét UDP có kiểm soát.....	12
8. Nhận diện dịch vụ và hệ điều hành	
8.1. Version detection (-sV).....	
8.2. OS detection (-O).....	

12 8.3. Aggressive scan (-A) - dùng để tổng hợp, không thay thế phân tích

13

Huynh Kòm – Thị Nở luôn là chân ái! [Trang 2 / 18](#)

TÀI LIỆU THỰC HÀNH AN TOÀN HỆ THỐNG THÔNG TIN | LƯU HÀNH NỘI BỘ

9. NSE - kiểm tra thông tin và lỗ hổng SMB trong lab 13

9.1. Thu thập thông tin SMB

13 9.2. Kiểm tra MS17-010

..... 13

10. Xuất kết quả và tạo hồ sơ bằng chứng

14 10.1. Xuất dạng normal text

..... 14 10.2. Xuất dạng

XML..... 14 10.3. Xuất

grepable và lọc nhanh 14 10.4.

Chuyển XML thành HTML..... 14

11. Tình huống - Trước và sau khi hardening..... 15

12. Phiếu báo cáo và tiêu chí nộp bài..... 15

12.1. Danh mục ảnh minh chứng bắt buộc 15

12.2. Câu hỏi phân tích 15

14. Bài tập bổ sung..... 16

14.1. Bài tập theo yêu cầu..... 16

14.2. Tình huống mở rộng: Lập bản đồ dịch vụ 17

14.3. Câu hỏi phân tích bổ sung 17

Tài liệu tham khảo..... 18

1. Mục tiêu, phạm vi và quy định thực hành

- Hiểu mô hình host/guest.
- Cài và kiểm tra Nmap trên Windows 10/11 và Kali Linux; hiểu vai trò của Npcap trên Windows.
- Tự dựng mạng VirtualBox Host-Only, xác định đúng IP của Kali, Metasploitable 2 và máy Windows.
- Thực hiện host discovery, TCP/UDP scan, service detection, OS fingerprinting, một số NSE script phòng thủ.
- Đọc và giải thích trạng thái open/closed/filtered; phân biệt kết quả giữa các kỹ thuật.
- Xuất kết quả, xây dựng bằng chứng và viết báo cáo kỹ thuật có khả năng lặp lại.

Phạm vi pháp lý và đạo đức

Bài lab chỉ áp dụng cho việc học tập và nghiên cứu, sinh viên sử dụng máy ảo của chính sinh viên trong mạng Host-Only và tạo ra máy mục tiêu để thực hành. Không sử dụng các kỹ thuật trong tài liệu để quét hệ thống công cộng, mạng cơ quan, Wi-Fi của người khác hay dịch vụ Internet khi chưa được phép. *Tôi hoàn toàn không chịu trách nhiệm khi các anh chị cố tình vượt ra khuôn khổ của bài tập thực hành.*

1.1. Chuẩn bị môi trường

Thành phần	Khuyến nghị	Ghi chú
Máy thật	Windows 10 hoặc Windows 11 64-bit	Tài khoản có quyền Administrator
RAM	Tối thiểu 8 GB; khuyến nghị 16 GB	Dành 2-4 GB cho Kali, 1 GB cho Metasploitable 2
Ổ đĩa trống	Tối thiểu 25-40 GB	Bao gồm VM và snapshot
Virtualization	Intel VT-x/AMD-V bật trong BIOS/UEFI	Kiểm tra trong Task Manager > Performance > CPU
VirtualBox	Bản hiện hành tương thích hệ điều hành	Không bắt buộc Extension Pack cho bài này
Kali Linux	VM cài sẵn hoặc ISO chính thức	Dùng làm máy quét
Metasploitable 2	Máy ảo mục tiêu cố ý có lỗ hổng	Chỉ nối Host-Only

Huynh Kòm – Thị Nở luôn là chân ái! Trang 4 / 18

TÀI LIỆU THỰC HÀNH AN TOÀN HỆ THỐNG THÔNG TIN | LƯU HÀNH NỘI BỘ

1.2. Quy tắc “tự gõ lệnh”

Không copy/paste câu lệnh từ LLM, chatbot hoặc web. Mỗi lệnh được chụp thành ảnh. Sinh viên phải tự gõ, tự sửa lỗi nếu sai và chụp lại màn hình sau khi lệnh chạy. Mục tiêu là hình thành kỹ năng đọc cú pháp, nhận biết dấu gạch ngang, khoảng trắng, địa chỉ IP và thông báo lỗi.

2. Cài đặt Nmap trên Windows 10/11

Theo tài liệu chính thức của Nmap, bản cài Windows dạng self-installer kèm lựa chọn Nmap, Npcap và Zenmap. Bản cài hiện hành có thể thay đổi theo thời điểm; sinh viên luôn tải từ trang chính thức của Nmap thay vì website bên thứ ba.

Nguồn tải chính thức: Mở trình duyệt và tự nhập địa chỉ: nmap.org/download.html.

Luôn tải bản ổn định mới nhất mà trang chính thức công bố tại thời điểm thực hành; không dùng số phiên bản cố định vì Nmap và Npcap được cập nhật thường xuyên. **2.1. Các bước cài**

Nmap + Npcap + Zenmap trên Windows

1. Mở trình duyệt, vào trang tải Nmap chính thức.
2. Trong mục Microsoft Windows binaries, chọn bản “Latest stable release self-installer”.
Không tải các bản crack/repack.
3. Sau khi tải xong, nhấp phải tệp cài đặt và chọn Run as administrator. 4. Chấp nhận giấy

phép. Ở màn hình chọn thành phần, giữ Nmap Core Files, Register Nmap Path, Npcap và Zenmap nếu được hiển thị.

5. Khi trình cài Npcap xuất hiện, giữ cấu hình mặc định trừ khi giảng viên yêu cầu khác. Hoàn thành Npcap trước rồi tiếp tục Nmap.

6. Kết thúc cài đặt. Đóng các cửa sổ Command Prompt/PowerShell cũ để biến PATH được nạp lại.

7. Mở Windows Terminal/PowerShell/Command Prompt bằng quyền Administrator và kiểm tra phiên bản.

```
C:\> nmap --version
C:\> npcap-wfp-loopback-adapter --help (không bắt buộc)
```

Hình 2.1. Lệnh kiểm tra Nmap trên Windows

Kết quả đạt: Màn hình phải hiển thị dòng Nmap version ... và thông tin platform. Nếu báo “nmap is not recognized...”, đóng/mở Terminal hoặc cài lại với tùy chọn đăng ký PATH.

Huynh Kôm – Thị Nở luôn là chân ái! Trang 5 / 18

TÀI LIỆU THỰC HÀNH AN TOÀN HỆ THỐNG THÔNG TIN | LƯU HÀNH NỘI BỘ

2.2. Kiểm tra địa chỉ IP Host-Only trên Windows

8. Mở VirtualBox và bảo đảm đã có một Host-Only Network (thường là 192.168.56.0/24). 9. Mở Command Prompt hoặc PowerShell.

10. Tự gõ lệnh bên dưới. Tìm adapter có tên tương tự “VirtualBox Host-Only Network”. 11. Ghi IPv4 Address và Subnet Mask vào phiếu thực hành. Không dùng IP Wi-Fi/Ethernet thật để quét.

```
C:\> ipconfig
```

Hình 2.2. Kiểm tra IP các adapter trên Windows.

3. Cài đặt Nmap trên Kali Linux

Kali Linux cung cấp gói nmap trong kho kali-rolling; trang công cụ chính thức của Kali hướng dẫn cài bằng apt. Nmap thường đã có sẵn trong nhiều image Kali, nhưng sinh viên vẫn phải kiểm tra thay vì giả định.

```
Real terminal capture from execution environment
$ uname -a
Linux dbad51fa0e33 6.18.44 #1 SMP Tue Sep 22 17:26:16 UTC 2026 x86_64 GNU/Linux
$ ip -br addr
lo                UNKNOWN    127.0.0.1/8 ::1/128
eth0              UP          172.26.39.223/22 fe80::605b:6fff:fe9c:e63b/64
[terminal remains open for capture]
```

Huỳnh Kòm – Thị Nở luôn là chân ái! Trang 6 / 18

TÀI LIỆU THỰC HÀNH AN TOÀN HỆ THỐNG THÔNG TIN | LƯU HÀNH NỘI BỘ

3.1. Kiểm tra và cài Nmap bằng apt

12. Khởi động Kali VM. Trong giai đoạn cài gói, có thể bật Adapter 1 = NAT để Kali truy cập Internet.
13. Mở Terminal. Cập nhật danh sách gói.
14. Cài gói nmap. Nếu hệ thống báo đã là phiên bản mới nhất thì không cần cài lại.
15. Kiểm tra phiên bản. Chụp ảnh màn hình làm minh chứng.
16. Sau khi hoàn tất cập nhật/cài gói, tắt Kali VM và ngắt NAT trước khi bắt đầu các bài quét. Chỉ giữ Host-Only Adapter.

```
kali@kali:~$ sudo apt update
```

Hình 3.1. Cập nhật danh sách gói Kali.

```
kali@kali:~$ sudo apt install nmap
```

Hình 3.2. Cài Nmap trên Kali.

```
kali@kali:~$ nmap --version
```

Hình 3.3. Kiểm tra phiên bản Nmap trên Kali.

3.2. Cài Zenmap trên Kali (tùy chọn)

Kho Kali hiện có gói zenmap. Zenmap hữu ích để sinh viên quan sát Ports/Hosts, Topology, Host Details và lịch sử scan; tuy nhiên phần chấm điểm chính vẫn dựa trên dòng lệnh Nmap.

```
kali@kali:~$ sudo apt install zenmap
```

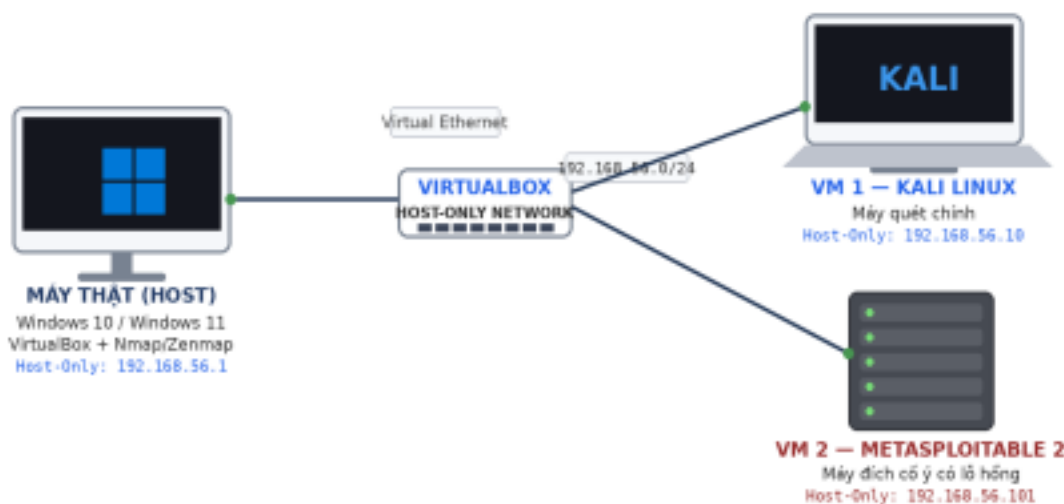
Hình 3.4. Cài Zenmap trên Kali (dùng khi cần giao diện đồ họa).

🌈 **Lưu ý:** Nếu Zenmap không mở. Không coi đây là lỗi Nmap. Sinh viên vẫn hoàn thành toàn bộ lab bằng Terminal. Kiểm tra lại DISPLAY/desktop session và gói phụ thuộc GTK; không cài phần mềm từ nguồn không rõ.

Huynh Kòm – Thị Nở luôn là chân ái! Trang 7 / 18

TÀI LIỆU THỰC HÀNH AN TOÀN HỆ THỐNG THÔNG TIN | LƯU HÀNH NỘI BỘ

4. Dựng môi trường máy ảo an toàn trên máy cá nhân



Hình

4.1. Sơ đồ topology mạng thực hành cá nhân: Windows Host, Kali Linux VM và Metasploitable 2 VM cùng kết nối qua VirtualBox Host-Only Network (Kali 192.168.56.10, Metasploitable 2 192.168.56.101).

- Đọc sơ đồ: máy Windows thật giao tiếp với hai VM qua adapter Host-Only 192.168.56.0/24. Kali là máy quét; Metasploitable 2 là máy đích. Không dùng Bridged cho Metasploitable 2.

4.1. Thiết lập Host-Only trong VirtualBox

17. Mở VirtualBox Manager.
18. Mở Tools/Network (tên menu có thể khác đôi chút theo phiên bản) và tạo Host-Only Network nếu chưa có.
19. Dùng dải riêng 192.168.56.0/24 hoặc dải do giảng viên chỉ định. Có thể bật DHCP để giảm cấu hình thủ công.

20. Kali VM: Adapter 1 = Host-Only Adapter. NAT chỉ bật tạm thời khi cần cập nhật; phải ngắt trước khi quét.
21. Metasploitable 2: chỉ dùng Host-Only Adapter. Tuyệt đối không Bridge máy này vào mạng thật.
22. Tạo snapshot “Before-LAB4” cho từng VM trước khi thực hành.

Huynh Kòm – Thị Nở luôn là chân ái! Trang 8 / 18

TÀI LIỆU THỰC HÀNH AN TOÀN HỆ THỐNG THÔNG TIN | LƯU HÀNH NỘI BỘ

4.2. Lấy IP thật của từng máy

```
kali@kali:~$ ip -br addr
```

Hình 4.2. Lấy IP trên Kali.

```
msfadmin@metasploitable:~$ ifconfig
```

Hình 4.3. Lấy IP trên Metasploitable 2.

Thiết bị	IP thực tế	Subnet	Ghi chú
Windows Host			VirtualBox Host Only adapter
Kali VM		 Máy quét	
Metasploitable 2			Máy đích
Windows VM (tùy chọn)			Máy đích đối chiếu

4.3. Kiểm tra kết nối trước khi quét

```
kali@kali:~$ ping -c 4 192.168.56.101
```

Hình 4.4. Kiểm tra kết nối Kali -> Metasploitable 2.

🚩 Lưu ý: **Nếu ping thất bại**: Không chuyển sang bước quét. Kiểm tra: (1) cả hai VM có cùng Host-Only Network; (2) subnet mask; (3) IP có trùng hay không; (4) máy đích đã khởi động; (5) firewall của máy đích có chặn ICMP hay không. Nếu ICMP bị chặn nhưng địa chỉ đúng, Nmap có thể cần -Pn ở các bài sau.

5. Tình huống giả lập: Rà soát an toàn mạng nội bộ

Bối cảnh: Bạn là kỹ thuật viên Blue Team của một phòng thực hành. Quản trị viên chỉ cung cấp dải mạng 192.168.56.0/24 và yêu cầu bạn lập bản kiểm kê các host, cổng, dịch vụ và rủi ro cơ bản trước khi nghiệm thu. Mọi mục tiêu đều là VM của chính bạn. Bạn không được giả định IP máy đích; phải phát hiện và chứng minh bằng kết quả quét.

5.1. Nhiệm vụ 1 - Phát hiện các host đang hoạt động

23. Từ Kali, xác nhận IP Host-Only của chính máy quét.

Huỳnh Kòm – Thị Nở luôn là chân ái! Trang 9 / 18

TÀI LIỆU THỰC HÀNH AN TOÀN HỆ THỐNG THÔNG TIN | LƯU HÀNH NỘI BỘ

24. Tự gõ lệnh host discovery cho toàn dải /24.

25. Ghi lại từng host “up”, địa chỉ MAC (nếu có) và nhà sản xuất NIC. 26. Đối chiếu số host với số VM đang bật. Nếu dư host, xác định đó có thể là adapter của máy thật hoặc DHCP service.



Hình 5.1. Host discovery trong mạng Host-Only.

STT	IP phát hiện	MAC/Vendor	Vai trò suy đoán	Bằng chứng
1				
2				
3				

6. Khảo sát cổng TCP và so sánh kỹ thuật quét

6.1. TCP Connect scan (-sT)



Hình 6.1. TCP Connect scan.

✓ Ghi tổng số cổng open/closed/filtered.

- ✓ Chọn ít nhất 3 cổng open và ghi dịch vụ được Nmap suy đoán.
- ✓ Nhận xét vì sao -sT không cần raw packet privileges như -sS.

6.2. SYN scan (-sS)



Hình 6.2. SYN scan - cần sudo/root hoặc quyền tương đương.

Tiêu chí	-sT	-sS	Nhận xét của sinh viên
Cổng open			
Cổng closed			
Cổng filtered			

Huỳnh Kòem – Thị Nở luôn là chân ái! Trang 10 / 18

TÀI LIỆU THỰC HÀNH AN TOÀN HỆ THỐNG THÔNG TIN | LƯU HÀNH NỘI BỘ

Tiêu chí	-sT	-sS	Nhận xét của sinh viên
Thời gian quét			
Quyền cần thiết			

6.3. FIN / Xmas / NULL scan

Ba kỹ thuật này được dùng để quan sát phản ứng TCP bất thường và sự khác biệt giữa các hệ điều hành/thiết bị lọc. Trong bài lab, chỉ chạy vào Metasploitable 2 và máy Windows VM của chính sinh viên nếu có.



Hình 6.3. FIN scan.



Hình 6.4. Xmas scan.



Hình 6.5. NULL scan.

☐ Chú ý: Điểm phải phân tích:

- Không được ghi đơn giản “open|filtered = open”. Trạng thái open|filtered nghĩa là Nmap không phân biệt được cổng mở hay bị bộ lọc làm im lặng. Kết quả phụ thuộc TCP/IP stack và firewall của mục tiêu.

6.4. ACK scan - quan sát chính sách lọc



Hình 6.6. ACK scan.

- ACK scan chủ yếu giúp phân biệt filtered và unfiltered, không phải công cụ khẳng định cổng open.
- So sánh kết quả ACK scan với SYN scan trên cùng mục tiêu.
- Giải thích một cổng “unfiltered” có ý nghĩa gì về khả năng gói ACK đi qua bộ lọc.

Huynh Kòm – Thị Nở luôn là chân ái! Trang 11 / 18

TÀI LIỆU THỰC HÀNH AN TOÀN HỆ THỐNG THÔNG TIN | LƯU HÀNH NỘI BỘ

7. Quét UDP có kiểm soát

UDP scan thường chậm và có nhiều trạng thái open|filtered vì UDP không có bắt tay như TCP. Để bài lab đủ thời gian, chỉ quét nhóm cổng phổ biến.



Hình 7.1. Quét 20 cổng UDP phổ biến.

Cổng UDP	Trạng thái	Dịch vụ	Giải thích/quan sát
.....			
.....			
.....			

8. Nhận diện dịch vụ và hệ điều hành

8.1. Version detection (-sV)



Hình 8.1. Nhận diện phiên bản dịch vụ.

Port	Protocol	Service	Version Nmap phát hiện	Ghi chú rủi ro
21	tcp	ftp		

22	tcp	ssh		
80	tcp	http		
445	tcp	smb		
3306	tcp	mysql		

8.2. OS detection (-O)



Hình 8.2. Fingerprinting hệ điều hành.

Huynh Kòm – Thị Nở luôn là chân ái! Trang 12 / 18

TÀI LIỆU THỰC HÀNH AN TOÀN HỆ THỐNG THÔNG TIN | LƯU HÀNH NỘI BỘ

8.3. Aggressive scan (-A) - dùng để tổng hợp, không thay thế phân tích



Hình 8.3. Aggressive scan tổng hợp.

- Ghi lại những thành phần -A cung cấp: version detection, OS detection, traceroute và default scripts.
- So sánh lượng thông tin và thời gian với -sV hoặc -O riêng lẻ.
- Giải thích vì sao một scan “nhiều thông tin” thường tạo nhiều lưu lượng và dễ bị phát hiện hơn.

9. NSE - kiểm tra thông tin và lỗ hổng SMB trong lab

Giới hạn: Chỉ chạy NSE vào Metasploitable 2 hoặc Windows VM do chính sinh viên quản lý. Mục tiêu là nhận biết dấu hiệu rủi ro để đề xuất biện pháp phòng thủ, không khai thác lỗ hổng.

9.1. Thu thập thông tin SMB



Hình 9.1. smb-os-discovery trên cổng 445.

- Ghi hệ điều hành/tên máy/domain nếu script trả về.

- Nếu cổng 445 đóng hoặc bị lọc, giải thích vì sao script không thể thu thập thông tin.

9.2. Kiểm tra MS17-010



Hình 9.2. NSE kiểm tra MS17-010.

- Cách kết luận: Chỉ ghi “có dấu hiệu dễ bị ảnh hưởng” khi script báo VULNERABLE. Nếu script báo không kết nối được, timed out hoặc không xác định, không được tự suy diễn là đã vá.

Huynh Kòm – Thị Nở luôn là chân ái! Trang 13 / 18

TÀI LIỆU THỰC HÀNH AN TOÀN HỆ THỐNG THÔNG TIN | LƯU HÀNH NỘI BỘ

Mục tiêu	445/tcp	Kết quả script	Kết luận	Biện pháp phòng thủ
Metasploitab le 2				
Windows VM (nếu có)				

10. Xuất kết quả và tạo hồ sơ bằng chứng

10.1. Xuất dạng normal text



Hình 10.1. Xuất kết quả dạng văn bản.

10.2. Xuất dạng XML



Hình 10.2. Xuất kết quả dạng XML.

10.3. Xuất grepable và lọc nhanh



Hình 10.3. Xuất greppable và lọc cổng 445 trên Kali.

Lưu ý: lệnh trên gồm hai bước — trước tiên nmap ... -oG smb.txt để tạo tệp smb.txt, sau đó grep "445/open" smb.txt để lọc. Phải chạy bước tạo tệp trước, nếu không sẽ báo "No such file".

10.4. Chuyển XML thành HTML



Hình 10.4. Chuyển Nmap XML thành HTML bằng xsltproc.

Huỳnh Kòm – Thị Nở luôn là chân ái! Trang 14 / 18

TÀI LIỆU THỰC HÀNH AN TOÀN HỆ THỐNG THÔNG TIN | LƯU HÀNH NỘI BỘ

11. Tình huống - Trước và sau khi hardening

❖ **Bối cảnh:** Sau vòng rà soát đầu tiên, quản trị viên tắt một dịch vụ không cần thiết hoặc bật firewall trên Windows VM. Nhiệm vụ của anh/chị là chứng minh thay đổi bằng hai bản quét trước/sau, không chỉ mô tả bằng lời.

27. Chọn một máy Windows VM của chính mình hoặc một dịch vụ test do giảng viên cung cấp trong Host-Only.

28. Chạy -sV và lưu kết quả “before”.

29. Thực hiện một thay đổi phòng thủ hợp pháp: tắt dịch vụ test, đóng một rule firewall, hoặc cập nhật cấu hình mạng.

30. Chạy lại đúng cùng câu lệnh và lưu kết quả “after”.

31. So sánh port state/service version và giải thích nguyên nhân thay đổi.

32. Khôi phục snapshot nếu thay đổi làm hỏng môi trường.

Chỉ tiêu	Before	After	Giải thích
Số cổng open			
Số cổng filtered			
Dịch vụ bị thay đổi			

Tác động an toàn			
------------------	-------	-------	-------

12. Phiếu báo cáo và tiêu chí nộp bài

12.1. Danh mục ảnh minh chứng bắt buộc

- Ảnh 1: ip -br addr trên Kali, thấy rõ interface Host-Only và IP.
- Ảnh 2: ifconfig/ip trên Metasploitable 2, thấy IP thật của máy đích.
- Ảnh 3: kết quả host discovery -sn.
- Ảnh 4: kết quả -sS hoặc -sT.
- Ảnh 5: kết quả -sV.
- Ảnh 6: kết quả -O hoặc -A.
- Ảnh 7: một NSE script và kết luận dựa trên chính output.
- Ảnh 8: tệp kết quả được lưu (.txt hoặc .xml) và/hoặc HTML nếu có.

12.2. Câu hỏi phân tích

1. Sự khác nhau giữa open, closed và filtered là gì? Nêu một tình huống mỗi trạng thái. Trả lời:

.....

Huynh Kòm – Thị Nở luôn là chân ái! Trang 15 / 18

TÀI LIỆU THỰC HÀNH AN TOÀN HỆ THỐNG THÔNG TIN | LƯU HÀNH NỘI BỘ

2. Tại sao -sS thường cần quyền cao hơn -sT? Hai kỹ thuật khác nhau ở cơ chế thiết lập kết nối như thế nào?

Trả lời:

3. Vì sao FIN/Xmas/NULL có thể cho kết quả khó diễn giải trên một số hệ điều hành hoặc firewall?

Trả lời:

4. ACK scan trả lời câu hỏi gì khác với SYN scan?

Trả lời:

5. Tại sao UDP scan thường chậm và dễ xuất hiện open|filtered?

Trả lời:

6. -sV đóng vai trò gì trong quản lý lỗ hổng? Tại sao chỉ biết port 80 là chưa đủ? Trả lời: 7.

OS fingerprinting có những giới hạn nào? Vì sao không nên coi kết quả -O là tuyệt

đối?

Trả lời:

8. NSE script báo timeout có đồng nghĩa “không có lỗ hổng” không? Giải thích. Trả lời: 9. So sánh before/after hardening: thay đổi nào trong port state chứng minh biện pháp phòng thủ có hiệu lực?

Trả lời:

10. Nêu ba cấu hình phòng thủ giúp giảm bề mặt tấn công mà không dựa vào “ẩn mình” trước Nmap.

Trả lời:

14. Bài tập bổ sung

14.1. Bài tập theo yêu cầu

1. So sánh -sT, -sS và -sA trên cùng máy Metasploitable 2. Lập bảng số cổng open/closed/filtered của mỗi kỹ thuật và giải thích khác biệt.
2. Quét toàn bộ 65535 cổng của máy đích, so sánh danh sách cổng với lần quét mặc định (1000 cổng). Có cổng nào chỉ xuất hiện ở lần quét đầy đủ không?
3. Chạy -sV rồi tra cứu ít nhất một dịch vụ có phiên bản cũ; ghi lại tên lỗ hổng (CVE) tương ứng nếu có.

Huỳnh Kòmm – Thị Nở luôn là chân ái! Trang 16 / 18

TÀI LIỆU THỰC HÀNH AN TOÀN HỆ THỐNG THÔNG TIN | LƯU HÀNH NỘI BỘ

4. Dùng NSE smb-vuln-ms17-010 trên Metasploitable 2 và trên một máy Windows đã cập nhật (nếu có), so sánh và giải thích kết quả.
5. Thực hiện quét có -D (decoy) và quét thường, quan sát log/kết quả và nêu ý nghĩa phòng thủ của kỹ thuật né tránh.
6. Xuất kết quả ra cả ba định dạng bằng -oA, mở tệp .nmap, .xml và .gnmap để so sánh cách trình bày.

14.2. Tình huống mở rộng: Lập bản đồ dịch vụ

Giả sử quản trị viên yêu cầu bạn lập "bản đồ dịch vụ" của toàn dải 192.168.56.0/24: liệt kê mỗi host đang sống, các cổng mở và dịch vụ tương ứng. Thực hiện host discovery, sau đó quét -sV cho từng host tìm được và tổng hợp vào một bảng. Nêu 3 dịch vụ rủi ro nhất và đề xuất biện pháp khắc phục cho mỗi dịch vụ.

14.3. Câu hỏi phân tích bổ sung

11. Vì sao quét toàn bộ 65535 cổng lại tốn nhiều thời gian hơn hẳn quét mặc định? Khi nào cần quét đầy đủ?

Trả lời:

12. Kỹ thuật decoy (-D) và fragmentation (-f) giúp kẻ tấn công né tránh thế nào, và IDS/firewall cần làm gì để chống lại?

Trả lời:

13. Giải thích vì sao -oA (xuất cả ba định dạng) hữu ích khi làm hồ sơ bằng chứng cho một cuộc đánh giá.

Trả lời:

14. Nếu một host trả về toàn bộ cổng ở trạng thái filtered, điều đó gợi ý gì về cấu hình firewall của host đó?

Trả lời: Tài liệu tham khảo

chính thức18

Huynh Kòm – Thị Nở luôn là chân ái! **Trang 17 / 18**

TÀI LIỆU THỰC HÀNH AN TOÀN HỆ THỐNG THÔNG TIN | LƯU HÀNH NỘI BỘ

Tài liệu tham khảo

[1] Nmap Project, “Download the Free Nmap Security Scanner for Linux/Mac/Windows,” nmap.org/download.html (truy cập 09/2026).

[2] Nmap Project, “Windows - Nmap Network Scanning,”

nmap.org/book/inst-windows.html. [3] Nmap Project, “Nmap Reference Guide,”

nmap.org/book/man.html. [4] Kali Linux, “nmap | Kali Linux Tools,” kali.org/tools/nmap/.

[5] Kali Linux Documentation, “Kali inside VirtualBox (Guest VM),”

kali.org/docs/virtualization/install-virtualbox-guest-vm/.

[6] Rapid7, “Metasploitable 2,” tài liệu máy ảo mục tiêu cố ý dễ bị tổn thương cho học tập.

[7] Microsoft Security Bulletin MS17-010, thông tin lỗ hổng SMB được WannaCry/EternalBlue khai thác.